Universidad Técnica Nacional (UTN)

Informe técnico de pruebas de seguridad

Laboratorio de seguridad de expedientes académicos

Curso	Pruebas de Software
Código de curso	ISW-622
Grupo	02
Docente	Andres Joseph Jimenez Leandro
Integrantes	Josué David Solís Gamboa Bernal Santiago Vargas Solís
Proyecto y versión	Laboratorio de seguridad de expedientes académicos · versión 1.1.0
Fecha de entrega	30/10/2026
Fecha de generación	2026-10-30 · commit del código `dafa7ba`

> Material didáctico. Todos los datos, usuarios y tokens son sintéticos; las pruebas se ejecutaron solo en 127.0.0.1.

Resumen ejecutivo

Se diseñó y ejecutó una campaña de pruebas de seguridad sobre el laboratorio local de expedientes académicos (UTN Central y UTN Pacífico). Se definieron **6 activos**, **8 amenazas** y **7 requisitos verificables** (SEC-01 a SEC-07), se diseñaron **23 casos** (los 12 obligatorios más 11 adicionales) y se automatizaron **34 pruebas** (23 de unidad y 11 de integración con la API). Se aplicaron **4 ciclos rojo-verde-refactor** con commits verificables (2 obligatorios y 2 adicionales), se corrigieron 5 hallazgos y quedan 3 aceptados como riesgo residual y 1 abierto.

100.0 %	100.0 %	100.0 %	15/15
Tasa de aprobación	Avance de ejecución	Cobertura de requisitos	Mutaciones detectadas

Decisión: LIBERAR CON CONDICIONES para el uso didáctico local; **NO LIBERAR** para cualquier uso real. Una tasa de aprobación alta no autoriza por sí sola la liberación (ver sección 6).

1. Alcance, activos, flujo de datos y amenazas

1.1 Alcance

Se evalúa el servicio local compuesto por `servidor.py` (API HTTP en 127.0.0.1:8765) y `src/lab.py` (modelo de negocio), con dos sedes (UTN Central en Alajuela y UTN Pacífico) y los roles estudiante, docente y administrador. La política de acceso es:

Rol	Lectura	Cambio de nota
Estudiante	Solo su expediente	Prohibido
Docente	Expedientes de su sede	Solo de su sede
Administrador	Expedientes de ambas sedes	Prohibido
Sin sesión / sesión inválida	Prohibido	Prohibido

Fuera de alcance: autenticación real, HTTPS, persistencia en base de datos y cualquier sistema distinto del laboratorio. Usuarios sintéticos: Ana (estudiante, Central), Luis (estudiante, Pacífico), María (docente, Central), Pedro (docente, Pacífico), Admin y una sesión vencida.

1.2 Activos

ID	Activo	Descripción	Propiedad de seguridad
A-01	Expedientes académicos	Registros con identificador, estudiante, sede y nota (`estado["expedientes"]`).	Confidencialidad, integridad
A-02	Notas	Dato crítico y modificable; su alteración equivale a fraude académico.	Integridad
A-03	Sesiones y tokens sintéticos	Tokens `lab-*` con banderas de revocación/expiración y `expira_en` (`estado["sesiones"]`).	Autenticidad, disponibilidad
A-04	Bitácora de auditoría	Lista en memoria con usuario, acción, ID y resultado (`estado["auditoria"]`).	Trazabilidad, confidencialidad
A-05	Política de permisos	Roles (estudiante, docente, administrador) y sedes (Central, Pacífico): `USUARIOS`, `_puede_leer`, regla de escritura.	Autorización
A-06	API HTTP local	`servidor.py` en 127.0.0.1:8765: parseo de cabeceras, JSON y tamaño del cuerpo.	Disponibilidad, integridad de entrada

1.3 Flujo de datos

```
[Cliente: curl / PowerShell / Postman / pruebas]
       |  (1) HTTP + "Authorization: Bearer <token sintético>"      <== frontera de confianza
       v
[servidor.py]  _token() -> autenticar() (POST) -> _leer_nota() (Content-Length, JSON, 1024 bytes)
       |  (2) llamada Python con (estado, token, id, nota)
       v
[src/lab.py]   autenticar -> autorizar (rol / sede / propiedad) -> validar nota -> persistir -> auditar
       |  (3) lee/escribe  A-01 expedientes, A-02 notas, A-03 sesiones, A-04 bitácora (memoria del proceso)
       v
[servidor.py]  _salida(): JSON + "Cache-Control: no-store"
       |  (4) HTTP 200 / 400 / 401 / 403 / 404 / 413
       v
[Cliente]
```

La frontera de confianza está entre el cliente y `servidor.py`: todo lo que cruza (cabecera `Authorization`, ruta, cuerpo JSON) es entrada no confiable.

1.4 Amenazas priorizadas

ID	Actor	Acción de abuso	Activo	Impacto	Prioridad	Razonamiento de la prioridad
R-01	Estudiante autenticado (Ana)	Cambia el ID en la URL para leer el expediente de otra persona (IDOR).	A-01, A-02	Divulgación de notas y datos de terceros; pérdida de confidencialidad.	Alta	Probabilidad alta (basta cambiar un número) e impacto alto (datos académicos protegidos).
R-02	Docente de una sede	Lee o modifica expedientes de la otra sede.	A-01, A-02	Notas alteradas o divulgadas fuera de su ámbito; fraude académico.	Alta	Impacto alto sobre la integridad; probabilidad media (usuario legítimo con acceso parcial).
R-03	Estudiante o administrador	Invoca el cambio de nota (escalada vertical de privilegios).	A-02	Nota alterada sin autoridad; el administrador debería ser solo lectura.	Alta	Impacto alto (fraude) y endpoint conocido: probabilidad media-alta.
R-04	Persona con un token revocado o vencido	Reutiliza la sesión después de cerrarla o de su caducidad.	A-03, A-01	Acceso a información protegida tras terminar la sesión.	Alta	Impacto alto; probabilidad media (tokens guardados en historiales o scripts).
R-05	Docente descuidado o atacante con sesión docente	Envía notas fuera de rango o de tipo inesperado (-1, 1000, true, NaN, texto).	A-02	Corrupción de datos y cálculos de promedios inválidos.	Media	Impacto medio (acotado a su sede); probabilidad media.
R-06	Quien lea la bitácora o los logs	Extrae tokens vigentes de los registros de auditoría.	A-04, A-03	Suplantación de sesiones.	Media	Impacto alto, pero requiere acceso a los registros: probabilidad baja-media.

ID	Actor	Acción de abuso	Activo	Impacto	Prioridad	Razonamiento de la prioridad
R-07	Usuario autenticado sin privilegios	Prueba IDs y compara 404 contra 403 para descubrir qué expedientes existen.	A-01	Enumeración de expedientes; prepara ataques dirigidos.	Media	Impacto bajo-medio, probabilidad alta (automatizable).
R-08	Cliente malicioso o defectuoso	Envía JSON inválido, Content-Length negativo o excesivo, o cuerpo sin sesión.	A-06	Errores internos, solicitudes colgadas o filtración de reglas de validación.	Baja	Impacto bajo (laboratorio local de un solo usuario); probabilidad media.

2. Requisitos, criterios de aceptación y trazabilidad

2.1 Requisitos de seguridad verificables

ID	Categoría	Requisito observable
SEC-01	Autorización / confidencialidad	Si un estudiante solicita el expediente de otra persona, el servicio debe denegar la lectura (403), no incluir la nota en la respuesta y no modificar los registros. Un docente solo lee expedientes de su sede y el administrador lee los de ambas sedes.
SEC-02	Autorización / integridad	Solo un docente puede cambiar la nota de un expediente y solo si es de su sede; estudiantes, administradores y docentes de otra sede reciben 403 y la nota original permanece intacta.
SEC-03	Sesiones	Una solicitud sin sesión, con sesión desconocida, revocada o vencida (por bandera o por reloj) recibe 401 antes de cualquier otro procesamiento, sin acceso a datos y sin revelar la causa.
SEC-04	Validación	La nota debe ser un número finito en [0,100]; texto, null, booleanos, NaN, infinito, listas y valores fuera de rango reciben 400 y no se persisten.
SEC-05	Confidencialidad en errores	Las respuestas 401/403/400/404 no incluyen notas ni otros datos protegidos; el permiso se evalúa antes que el dato; y un ID inexistente es indistinguible de uno ajeno para quien no es administrador.
SEC-06	Trazabilidad	Cada lectura o actualización autenticada (permitida, denegada o rechazada) se registra con usuario, acción, ID de expediente y resultado, y la bitácora nunca contiene tokens.
SEC-07	Robustez de entrada	Un cuerpo JSON mal formado, que no sea un objeto, o con Content-Length negativo o no numérico se responde 400; un cuerpo mayor a 1024 bytes se responde 413; en ningún caso se alteran datos.

2.2 Criterios de aceptación (Dado-Cuando-Entonces)

ID	Requisito	Dado	Cuando	Entonces
CA-01	SEC-01	Ana (estudiante, Central) tiene una sesión vigente y existe el expediente 202 de Luis (Pacífico)	Ana solicita GET /expedientes/202	recibe 403 con {"error": "Operación denegada"}, sin nota, estudiante ni sede, y los expedientes no cambian
CA-02	SEC-02	María (docente, Central) tiene sesión vigente y el expediente 202 (Pacífico) tiene nota 91	María envía POST /expedientes/202/nota con {"nota": 10}	recibe 403 y la nota del expediente 202 sigue siendo 91
CA-03	SEC-03	Ana revocó su sesión (o su sesión superó `expira_en`)	Ana solicita GET /expedientes/101 con ese token	recibe 401 sin datos del expediente
CA-04	SEC-04	María tiene sesión vigente y el expediente 101 tiene nota 82	María envía POST /expedientes/101/nota con {"nota": 101}	recibe 400 y la nota del expediente 101 continúa en 82
CA-05	SEC-05	Luis (estudiante) tiene sesión vigente y el ID 999 no existe	Luis solicita GET /expedientes/999 y GET /expedientes/101 (de Ana)	ambas respuestas son idénticas (403 y mismo cuerpo), de modo que no puede saber qué IDs existen

2.3 Matriz de trazabilidad requisito - riesgo - caso de prueba

Requisito	Categoría	Amenazas	Casos de prueba	Estado
SEC-01	Autorización / confidencialidad	R-01, R-02	TC-01, TC-02, TC-07, TC-10	4/4 aprobados
SEC-02	Autorización / integridad	R-02, R-03	TC-03, TC-06, TC-08, TC-09	4/4 aprobados
SEC-03	Sesiones	R-04, R-08	TC-04, TC-13, TC-19, TC-22	4/4 aprobados
SEC-04	Validación	R-05	TC-05, TC-11, TC-14	3/3 aprobados
SEC-05	Confidencialidad en errores	R-01, R-05, R-07	TC-12, TC-16, TC-20, TC-21	4/4 aprobados
SEC-06	Trazabilidad	R-06	TC-15	1/1 aprobados
SEC-07	Robustez de entrada	R-08	TC-17, TC-18, TC-23	3/3 aprobados

La matriz completa (un renglón por requisito y caso, con evidencia esperada y obtenida) está en `matriz_trazabilidad.csv`.

3. Diseño de casos, TDD y ejecución

3.1 Los 12 casos de diseño (3 positivos, 6 negativos, 3 de frontera)

Cada caso registra identificador, requisito, amenaza, precondiciones, entradas, pasos, resultado esperado (oráculo) y evidencia (plantilla A.1). Los resultados se obtienen de la ejecución real de la suite; `casos_prueba.csv` contiene la misma información.

ID	Caso y objetivo	Precondiciones	Entradas y pasos	Resultado esperado	Estado y evidencia

TC-01
Positivo
Alta
	Estudiante lee su propio expediente
	SEC-01 · R-01
	Confirmar que el control no bloquea la lectura legítima.
		Sesión `lab-ana` vigente (Ana, estudiante, Central); expediente 101 de Ana con nota 82.	GET /expedientes/101 con `Authorization: Bearer lab-ana`.
			Pasos: 1) Enviar la solicitud. 2) Revisar código y cuerpo.
				200; cuerpo con estudiante `ana` y nota 82.	Aprobado
					Unidad + API
					`test_TC01_estudiante_lee_su_expediente`
					`test_api_TC01_estudiante_lee_su_expediente`

ID	Caso y objetivo	Precondiciones	Entradas y pasos	Resultado esperado	Estado y evidencia
TC-02 Negativo Alta	**Estudiante A intenta leer el expediente de B** SEC-01 · R-01 Verificar denegación sin filtrar datos (acceso horizontal).	Sesión `lab-ana` vigente; expediente 202 pertenece a Luis (Pacífico), nota 91.	GET /expedientes/202 con `Bearer lab-ana`. **Pasos:** 1) Enviar. 2) Comprobar código. 3) Buscar nota, estudiante, sede o `91` en el cuerpo. 4) Comparar los expedientes antes/después.	403; el cuerpo no contiene nota, estudiante ni sede; expedientes sin cambios.	**Aprobado** Unidad + API `test_TC02_estudiante_no_lee_expediente_ajeno` `test_api_TC02_estudiante_no_lee_expediente_ajeno_y_no_filtra` Manual: PM-01
TC-03 Negativo Alta	**Docente de una sede cambia la nota de otra sede** SEC-02 · R-02 Verificar integridad entre sedes (acceso horizontal de escritura).	Sesión `lab-maria` (docente, Central); expediente 202 (Pacífico) con nota 91.	POST /expedientes/202/nota con {"nota": 10}. **Pasos:** 1) Enviar. 2) Comprobar código. 3) Releer el expediente 202 como administrador.	403; la nota de 202 permanece en 91; expedientes sin cambios.	**Aprobado** Unidad + API `test_TC03_docente_no_modifica_nota_de_otra_sede` `test_api_TC03_docente_no_modifica_otra_sede` Manual: PM-02
TC-04 Negativo Alta	**Sesión revocada o vencida** SEC-03 · R-04 Verificar que una sesión no vigente no accede a nada.	a) `lab-ana` revocada con POST /sesiones/revocar. b) `lab-vencida` (marcada vencida). c) sesión marcada `expirada` con `expira_en` futuro.	GET /expedientes/101 y POST /expedientes/101/nota con cada token. **Pasos:** 1) Revocar (caso a). 2) Solicitar lectura y escritura. 3) Repetir con b y c.	401 en todos; cuerpo sin datos; nota intacta.	**Aprobado** Unidad + API `test_TC04a_sesion_revocada_no_accede` `test_TC04b_sesion_vencida_no_lee_ni_modifica` `test_TC04c_bandera_expirada_prevalece_aunque_el_reloj_no_haya_vencido` `test_api_TC04_sesiones_revocada_y_vencida_reciben_401` Manual: PM-05, PM-06
TC-05 Frontera Media	**Nota fuera de [0,100]** SEC-04 · R-05 Rechazar valores justo fuera del rango y no persistirlos.	Sesión `lab-maria` vigente; expediente 101 con nota 82.	Notas -1, -0.01, 100.01, 101 y 1000. **Pasos:** 1) Enviar cada valor. 2) Comprobar 400. 3) Releer la nota.	400 en cada caso; la nota sigue en 82.	**Aprobado** Unidad + API `test_TC05_nota_fuera_de_rango_se_rechaza_y_no_persiste` `test_api_TC05_nota_fuera_de_rango_da_400_y_no_persiste` Manual: PM-03
TC-06 Positivo Alta	**Docente cambia una nota de su sede** SEC-02 · R-02 Confirmar que el cambio legítimo funciona y persiste.	Sesión `lab-maria` (Central); expediente 101 (Central) con nota 82.	POST /expedientes/101/nota con {"nota": 85}. **Pasos:** 1) Enviar. 2) Releer el expediente.	200; la nota persistida es 85.	**Aprobado** Unidad + API `test_TC06_docente_actualiza_nota_de_su_sede` `test_api_TC06_docente_actualiza_nota_de_su_sede`
TC-07 Positivo Media	**Administrador lee expedientes de ambas sedes** SEC-01 · R-01 Confirmar que el administrador conserva la lectura global.	Sesión `lab-admin`; expedientes 101 (Central) y 202 (Pacífico).	GET /expedientes/101 y GET /expedientes/202. **Pasos:** 1) Enviar ambas solicitudes.	200 en ambas.	**Aprobado** Unidad `test_TC07_admin_lee_expedientes_de_ambas_sedes`
TC-08 Negativo Alta	**Administrador intenta cambiar una nota** SEC-02 · R-03 Verificar escalada vertical: el administrador es solo lectura.	Sesión `lab-admin`; expediente 101 con nota 82.	POST /expedientes/101/nota con {"nota": 100}. **Pasos:** 1) Enviar. 2) Releer el expediente.	403; nota intacta.	**Aprobado** Unidad + API (ps1) `test_TC08_admin_no_modifica_notas`
TC-09 Negativo Alta	**Estudiante intenta cambiar su propia nota** SEC-02 · R-03 Verificar escalada vertical del estudiante.	Sesión `lab-ana`; expediente 101 con nota 82.	POST /expedientes/101/nota con {"nota": 100}. **Pasos:** 1) Enviar. 2) Releer el expediente.	403; nota intacta.	**Aprobado** Unidad + API (ps1) `test_TC09_estudiante_no_modifica_su_propia_nota`
TC-10 Negativo Alta	**Docente intenta leer un expediente de otra sede** SEC-01 · R-02 Verificar la lectura restringida a la sede propia.	Sesión `lab-maria` (Central); expediente 202 (Pacífico).	GET /expedientes/202 con `Bearer lab-maria`. **Pasos:** 1) Enviar. 2) Revisar código y cuerpo.	403; el cuerpo no contiene nota, estudiante ni sede.	**Aprobado** Unidad `test_TC10_docente_no_lee_expediente_de_otra_sede`
TC-11 Frontera Media	**Notas límite 0 y 100** SEC-04 · R-05 Confirmar que los extremos inclusivos se aceptan.	Sesión `lab-maria`; expediente 101.	Notas 0 y 100. **Pasos:** 1) Enviar 0. 2) Enviar 100. 3) Releer tras cada envío.	200 en ambos; la nota persistida coincide.	**Aprobado** Unidad + API (ps1) `test_TC11_limites_0_y_100_son_validos`

ID	Caso y objetivo	Precondiciones	Entradas y pasos	Resultado esperado	Estado y evidencia
TC-12 Frontera Media	**Expediente inexistente no permite enumerar IDs** SEC-05 · R-07 Verificar que 999 (inexistente) y 202 (ajeno) son indistinguibles para no administradores.	Sesiones `lab-ana`, `lab-maria`, `lab-admin`; el ID 999 no existe.	GET /expedientes/999 y GET /expedientes/202 con cada token. **Pasos:** 1) Solicitar ambos IDs por rol. 2) Comparar código y cuerpo.	Estudiante y docente: respuestas idénticas (403). Administrador: 404 sin datos.	Aprobado Unidad + API (ps1) `test_TC12_expediente_inexistente_no_permite_enumerar_ids` Manual: PM-07, PM-08

3.2 Casos adicionales (no cuentan para el mínimo de 12)

ID	Caso y objetivo	Precondiciones	Entradas y pasos	Resultado esperado	Estado y evidencia
TC-13 Negativo Alta	**Token ausente o desconocido** SEC-03 · R-04 Sin sesión no hay acceso.	Ninguna.	GET /expedientes/101 sin cabecera y con `Bearer lab-inexistente`. **Pasos:** 1) Enviar ambas.	401; cuerpo sin datos.	Aprobado Unidad + API (ps1) `test_TC13_token_ausente_o_desconocido_da_401`
TC-14 Negativo Media	**Tipos inválidos de nota** SEC-04 · R-05 Rechazar valores que no son números reales.	Sesión `lab-maria`.	"85", null, true, NaN, inf, [85]. **Pasos:** 1) Enviar cada valor.	400; nota intacta.	Aprobado Unidad + API (ps1) `test_TC14_tipos_invalidos_de_nota_se_rechazan`
TC-15 Adicional Media	**Auditoría registra denegados y nunca tokens** SEC-06 · R-06 Verificar usuario/acción/resultado y ausencia de tokens.	Estado nuevo.	Lectura propia, cambio legítimo y lectura ajena. **Pasos:** 1) Ejecutar las tres operaciones. 2) Inspeccionar `estado["auditoria"]`.	Resultados [permitida, permitida, denegada]; ningún campo `token`; ningún valor con `lab-`.	Aprobado Unidad `test_TC15_auditoria_registra_denegados_y_nunca_tokens`
TC-16 Negativo Media	**El permiso se evalúa antes que la validación del dato** SEC-05 · R-05 No revelar reglas de validación a quien no tiene permiso.	Sesión `lab-ana`.	Nota 5000 por un estudiante. **Pasos:** 1) Enviar.	403 (no 400).	Aprobado Unidad `test_TC16_permiso_se_evalua_antes_que_validacion_del_dato`
TC-17 Negativo Baja	**JSON mal formado o que no es objeto** SEC-07 · R-08 Rechazar cuerpos inválidos sin alterar datos.	Sesión `lab-maria`.	`{nota:`, `[85]` y cuerpo vacío. **Pasos:** 1) Enviar cada cuerpo.	400; nota intacta.	Aprobado API `test_api_TC17_json_invalido_o_no_objeto_da_400` Manual: PM-04
TC-18 Negativo Baja	**Content-Length negativo o excesivo** SEC-07 · R-08 Evitar solicitudes colgadas y cuerpos grandes.	Sesión `lab-maria`.	Content-Length: -1 y Content-Length: 2048. **Pasos:** 1) Enviar cada cabecera.	400 y 413 respectivamente.	Aprobado API `test_api_TC18_content_length_negativo_da_400_y_exceso_da_413`

TC-19
Frontera
Alta
	Caducidad de la sesión por reloj
	SEC-03 · R-04
	La sesión caduca en `expira_en` (ciclo TDD 2).
		Reloj inyectado; `expira_en` = 1000.	Reloj en 999.999, 1000 y 1500; revocar tras vencer.
			Pasos: 1) Fijar el reloj. 2) Leer y modificar.
				200 antes del instante; 401 en y después del instante; toda sesión nueva tiene `expira_en`.	Aprobado
					Unidad
					`test_TC19a_sesion_con_expiracion_pasada_no_lee_ni_modifica`
					`test_TC19b_frontera_de_expiracion`
					`test_TC19c_sesion_vencida_por_reloj_no_se_puede_revocar_como_vigente`
					`test_TC19d_sesiones_nuevas_tienen_vigencia_finita`

TC-20 Negativo Media	**Escribir sobre un ID inexistente no permite enumerar** SEC-05 · R-07 El 403 de escritura es idéntico para IDs ajenos e inexistentes (ciclo TDD 1).	Sesiones `lab-ana`, `lab-maria`, `lab-admin`.	POST nota sobre 202 y sobre 999. **Pasos:** 1) Enviar a ambos IDs por rol.	Respuestas idénticas (403); datos intactos.	Aprobado Unidad `test_TC20_escritura_sobre_id_inexistente_no_permite_enumerar`
TC-21 Adicional Baja	**Respuestas sin caché** SEC-05 · R-01 Evitar que proxies o navegadores guarden notas.	Sesión `lab-ana`.	GET /expedientes/101. **Pasos:** 1) Revisar cabeceras.	`Cache-Control: no-store`.	Aprobado API `test_api_TC21_respuestas_no_se_almacenan_en_cache`
TC-22 Negativo Media	**Sin sesión válida el 401 precede a la validación del cuerpo** SEC-03 · R-08 Autenticar antes de interpretar el cuerpo (ciclo TDD 3).	Ninguna.	POST con token ausente, desconocido o vencido y cuerpos inválidos. **Pasos:** 1) Enviar 9 combinaciones.	401 en todas; el cuerpo no describe errores de validación.	Aprobado API `test_api_TC22_sin_sesion_valida_recibe_401_antes_de_validar_el_cuerpo`

ID	Caso y objetivo	Precondiciones	Entradas y pasos	Resultado esperado	Estado y evidencia
TC-23 Negativo Media	**El 401 llega completo aunque el cliente envíe cuerpo** SEC-07 · R-08 El servidor consume el cuerpo antes de cerrar (ciclo TDD 4).	Ninguna.	200 solicitudes sin sesión con cuerpo de ~900 bytes. **Pasos:** 1) Repetir la solicitud 200 veces.	401 en todas; ninguna conexión abortada.	Aprobado API `test_api_TC23_el_401_llega_completo_aunque_el_cliente_envie_cuerpo`

3.3 Automatización y diversidad

Se automatizaron **34 pruebas** en `tests/`: 23 de unidad sobre la lógica de negocio (`test_laboratorio.py`) y 11 de integración contra el servidor HTTP real en un puerto efímero de 127.0.0.1 (`test_api.py`). Los 23 casos tienen al menos una prueba automatizada; además hay 10 pruebas manuales y 21 comprobaciones de API con `ejecutar_todo.ps1`. No se duplicaron pruebas para alcanzar el mínimo: cada caso cubre una combinación distinta de rol, sede, sesión o entrada.

3.4 Ciclos rojo-verde-refactor

> **Nota de transparencia.** El código base disponible en el repositorio ya contenía las correcciones de autorización, sesiones revocadas y validación de nota; no se conserva una versión vulnerable ni su historial. Por eso los ciclos se ejecutaron sobre debilidades que seguían abiertas y cada paso es un commit real que se puede verificar con `git show <hash>` y reproducir con `git checkout <hash>`.

El enunciado exige dos ciclos: el **ciclo 1** está vinculado con acceso indebido y el **ciclo 2** con la validez de la sesión. Los ciclos 3 y 4 son adicionales y surgieron de la inspección estática y de una prueba intermitente. Por cada ciclo se guardan tres evidencias (plantilla A.3): rojo fallando por el motivo correcto, verde con el cambio mínimo y refactor con la suite otra vez aprobada. Las salidas completas y saneadas están en `evidencias/tdd/` y el mapa de hashes en `evidencias/tdd/REGISTRO_TDD.md`.

Ciclo 1: Acceso indebido: enumeración de expedientes

Requisito: SEC-05 (amenaza R-07, relacionado con SEC-01) · **Hallazgo:** H-01

- **Rojo:** TC-12 y TC-20 fallan con `403 != 404`: un ID inexistente respondía 404 y uno ajeno 403, lo que permite descubrir qué expedientes existen.
- **Verde:** Cambio mínimo: cuando el expediente no existe y el rol no es administrador, se responde el mismo 403 auditado.
- **Refactor:** `_denegar()` centraliza el 403 y su auditoría; los caminos de lectura y escritura ya no pueden divergir.

Paso	Commit	Evidencia	Pruebas	Aprobadas	Fallidas	Tasa
ROJO	`a501914`	`evidencias/tdd/ciclo1_1_ROJO.txt`	27	25	2	92.6 %
VERDE	`d7fe59d`	`evidencias/tdd/ciclo1_2_VERDE.txt`	27	27	0	100.0 %
REFACTOR	`e29e531`	`evidencias/tdd/ciclo1_3_REFACTOR.txt`	27	27	0	100.0 %

Ciclo 2: Validez de la sesión: caducidad por reloj

Requisito: SEC-03 (amenaza R-04) · **Hallazgo:** H-02

- **Rojo:** TC-19a/b/c fallan con `401 != 200` y TC-19d con `expira_en` ausente: una sesión con vigencia vencida seguía autenticando.
- **Verde:** Cambio mínimo: `expira_en` por sesión y reloj inyectable `estado["ahora"]`; se rechaza si `ahora >= expira_en`.
- **Refactor:** `_sesion_vigente()` unifica la regla entre `autenticar` y `revocar_sesion`.

Paso	Commit	Evidencia	Pruebas	Aprobadas	Fallidas	Tasa
ROJO	`335dfc4`	`evidencias/tdd/ciclo2_1_ROJO.txt`	31	27	4	87.1 %
VERDE	`7f7fd23`	`evidencias/tdd/ciclo2_2_VERDE.txt`	31	31	0	100.0 %
REFACTOR	`a3719fd`	`evidencias/tdd/ciclo2_3_REFACTOR.txt`	31	31	0	100.0 %

Ciclo 3: Sesión: autenticar antes de interpretar el cuerpo (adicional)

Requisito: SEC-03 (amenaza R-08) · **Hallazgo:** H-03

- **Rojo:** TC-22 falla con `401 != 400`: sin sesión y con JSON inválido el servidor describía el error de validación.
- **Verde:** Cambio mínimo: `do_POST` autentica antes de leer el cuerpo.
- **Refactor:** `no_autenticado()` define la respuesta 401 una sola vez.

Paso	Commit	Evidencia	Pruebas	Aprobadas	Fallidas	Tasa
ROJO	`ec13a34`	`evidencias/tdd/ciclo3_1_ROJO.txt`	32	31	1	96.9 %
VERDE	`724193d`	`evidencias/tdd/ciclo3_2_VERDE.txt`	32	32	0	100.0 %
REFACTOR	`7eff45f`	`evidencias/tdd/ciclo3_3_REFACTOR.txt`	32	32	0	100.0 %

Ciclo 4: El 401 podía perderse con un cuerpo sin consumir (adicional)

Requisito: SEC-03 / SEC-07 (amenaza R-08) · **Hallazgo:** H-04

- **Rojo:** TC-23 falla con `ConnectionAbortedError`: el servidor cerraba con datos pendientes y el cliente perdía la respuesta.
- **Verde:** Cambio mínimo: `_descartar_cuerpo()` consume hasta 1024 bytes antes de responder el 401.
- **Refactor:** `_leer_nota()` aísla la lectura del cuerpo y deja `do_POST` más corto.

Paso	Commit	Evidencia	Pruebas	Aprobadas	Fallidas	Tasa
ROJO	`9f73de3`	`evidencias/tdd/ciclo4_1_ROJO.txt`	34	33	1	97.1 %
VERDE	`fff5be1`	`evidencias/tdd/ciclo4_2_VERDE.txt`	34	34	0	100.0 %
REFACTOR	`dafa7ba`	`evidencias/tdd/ciclo4_3_REFACTOR.txt`	34	34	0	100.0 %

3.5 Ejecución en estado limpio y regresión

La suite se ejecutó dos veces desde clones nuevos del repositorio (`tools/ejecucion_limpia.py`, comando `python -m unittest discover -s tests -v`). Cada ejecución registra comando, versiones, commit y resultado en `evidencias/ejecucion_limpia_N.txt`. La regresión es la propia suite completa: tras cada commit de verde y de refactor se repitió la suite entera (`evidencias/tdd/`), no solo la prueba que fallaba.

Ejecución	Commit del código	Python y sistema	Resultado	Estado
Ejecución limpia 1	`d680096`	3.12.10 (Windows 11)	34 pruebas en 5.758 s	Aprobada
Ejecución limpia 2	`d680096`	3.12.10 (Windows 11)	34 pruebas en 5.760 s	Aprobada

3.6 Pruebas manuales por la API (análisis dinámico)

Se ejecutaron 10 solicitudes con `curl.exe` contra el servidor local (incluye acceso entre sedes y entrada inválida). Comandos y respuestas literales en `evidencias/pruebas_manuales_api.md`.

ID	Prueba	Caso / requisito	Resultado observado
PM-01	Ana intenta leer el expediente de Luis	TC-02 / SEC-01 (acceso horizontal entre estudiantes)	HTTP 403
PM-02	Maria (Central) intenta cambiar la nota de un expediente de Pacifico	TC-03 / SEC-02 (acceso entre sedes, escritura)	HTTP 403
PM-03	Maria envia una nota fuera de rango (101)	TC-05 / SEC-04 (entrada invalida)	HTTP 400
PM-04	Maria envia JSON mal formado	TC-17 / SEC-07 (entrada invalida)	HTTP 400
PM-05	Ana revoca su sesion	TC-04 / SEC-03 (sesion revocada, paso 1)	HTTP 200
PM-06	Ana reutiliza la sesion revocada	TC-04 / SEC-03 (sesion revocada, paso 2)	HTTP 401
PM-07	Luis consulta un ID inexistente (999)	TC-12 / SEC-05 (enumeracion, estudiante)	HTTP 403
PM-08	El administrador consulta un ID inexistente (999)	TC-12 / SEC-05 (enumeracion, administrador)	HTTP 404
PM-09	El administrador comprueba que el expediente 101 conserva su nota original (82)	Integridad tras los rechazos (SEC-02, SEC-04)	{"id": "101", "estudiante": "ana", "sede": "Central", "nota": 82}
PM-10	El administrador comprueba que el expediente 202 conserva su nota original (91)	Integridad tras los rechazos (SEC-02)	{"id": "202", "estudiante": "luis", "sede": "Pacifico", "nota": 91}

3.7 Inspección estática (SAST) con lista de comprobación

El código se revisó **sin ejecutarlo** con una lista de 24 comprobaciones sobre permisos, sesiones, validación, manejo de errores, exposición de datos, auditoría, configuración y secretos (21 cumplen). La herramienta bandit 1.9.4 no reportó alertas (`evidencias/sast_bandit.txt`), resultado que se considera no concluyente para la lógica de autorización. Se distingue del análisis dinámico de la sección 3.6, donde sí se envían solicitudes al sistema en ejecución.

#	Comprobación	Resultado	Área
C-01	La lectura depende de rol, sede y propiedad, no solo de tener sesion	Cumple	Permisos
C-02	Solo el docente de la sede del expediente puede modificar notas	Cumple	Permisos
C-03	El permiso se evalua antes que la validacion del dato	Cumple	Permisos
C-04	Hay una unica via de decision de acceso, sin rutas alternas que la eviten	Cumple	Permisos
C-05	Sesion ausente, desconocida, revocada o expirada (bandera o reloj) se rechaza	Cumple	Sesiones
C-06	Revocar una sesion invalida produce el mismo 401 (no revela su estado)	Cumple	Sesiones
C-07	La nota se valida por tipo y rango; rechaza bool, NaN e infinito	Cumple	Validacion
C-08	El cuerpo JSON se valida (objeto, tamano maximo, Content-Length)	Cumple	Validacion
C-09	El ID de la ruta se usa solo como clave de un diccionario (sin archivos ni SQL)	Cumple	Validacion
C-10	Los errores esperados no producen trazas ni detalles internos hacia el cliente	Cumple	Manejo de errores
C-11	Existe un manejador general para excepciones inesperadas	Parcial	Manejo de errores
C-12	401/403/400 no incluyen campos del expediente	Cumple	Exposicion de datos
C-13	Un ID inexistente no se distingue de uno ajeno para quien no es administrador	Cumple (corregido en el ciclo TDD 1)	Exposicion de datos
C-14	Las respuestas no se guardan en cache	Cumple	Exposicion de datos
C-15	El registro del servidor no escribe el encabezado `Authorization`	Cumple	Exposicion de datos
C-16	La respuesta 200 devuelve una copia del expediente, no la referencia interna	Cumple	Exposicion de datos
C-17	Se registra usuario, accion, ID y resultado y nunca el token	Cumple	Auditoria
C-18	Los intentos denegados y rechazados tambien se auditan	Cumple	Auditoria
C-19	Los intentos sin sesion valida (401) y las revocaciones se auditan	**No cumple** (limitacion)	Auditoria
C-20	El servidor solo escucha en la interfaz local	Cumple	Configuracion
C-21	El estado compartido esta protegido ante solicitudes simultaneas	**No cumple** (limitacion)	Concurrencia
C-22	No hay credenciales reales en el repositorio	Cumple	Secretos
C-23	La autenticacion ocurre antes de procesar el cuerpo de la solicitud	Cumple (corregido en el ciclo TDD 3; antes: No cumple)	Sesiones
C-24	El servidor consume el cuerpo pendiente antes de cerrar, para que el 401 no se pierda por un reinicio de la conexion	Cumple (corregido en el ciclo TDD 4; antes: No cumple)	Sesiones

3.8 Prueba de mutación (¿las pruebas pueden fallar cuando el control falla?)

`tools/mutaciones.py` rompe un control a la vez en una copia temporal y comprueba que alguna prueba falle. Resultado final: **15 de 15 mutaciones detectadas**. La primera ejecución dejó un mutante vivo (M-07, la bandera `expirada` estaba tapada por el reloj); se agregó TC-04c y quedó detectado (`evidencias/mutaciones_primera_ejecucion.txt` frente a `evidencias/mutaciones.md`).

Mutación	Requisito	Control roto	Detectada	Casos que fallan
M-01	SEC-01	El docente puede leer expedientes de cualquier sede	Sí	TC-10, TC-12
M-02	SEC-02	El docente puede modificar notas de otra sede	Sí	TC-03, TC-20
M-03	SEC-02	Se elimina la comprobacion de rol docente al modificar	Sí	TC-09, TC-16
M-04	SEC-04	Se elimina la validacion de rango de la nota	Sí	TC-05
M-05	SEC-04	Un booleano se acepta como nota	Sí	TC-14
M-06	SEC-03	Una sesion revocada sigue autenticando	Sí	TC-04
M-07	SEC-03	Se ignora la bandera 'expirada' (antes la tapaba el reloj)	Sí	TC-04
M-08	SEC-03	La sesion no caduca por reloj	Sí	TC-19
M-09	SEC-05	Un ID inexistente responde 404 a cualquier rol (enumeracion)	Sí	TC-12
M-10	SEC-05	Escribir sobre un ID inexistente deja de ser 403	Sí	TC-20
M-11	SEC-06	Las denegaciones dejan de auditarse	Sí	TC-15
M-12	SEC-06	La bitacora guarda un valor con forma de token	Sí	TC-15
M-13	SEC-03	El servidor procesa el cuerpo antes de autenticar	Sí	TC-22
M-14	SEC-05	Se elimina Cache-Control: no-store	Sí	TC-21
M-15	SEC-07	Se acepta Content-Length negativo	Sí	TC-18

4. Revisiones, usabilidad, hallazgos y conclusiones

4.1 Acta de inspección cruzada

Se inspeccionaron una política de acceso y dos casos de prueba. Las observaciones son verificables y cada una enlaza con su hallazgo.

Campo	Contenido
Revisor	Josué David Solís Gamboa
Autor revisado	Bernal Santiago Vargas Solís
Fecha	30/10/2026
Objetos inspeccionados	1) Política de acceso (tabla rol - operación, `_puede_leer` y la condición de escritura en `lab.py:122`). 2) Caso TC-03 (docente cambia nota de otra sede). 3) Caso TC-12 (enumeración de IDs).
Observaciones del revisor	Confirma OBS-01 a OBS-04 sin observaciones adicionales. La política de acceso y los casos TC-03 y TC-12 se consideran correctos y sus pruebas verifican el efecto sobre los datos.

ID	Observación verificable	Severidad	Acción tomada	Hallazgo
OBS-01	La política original no define qué responder ante un ID inexistente; 404 frente a 403 permitía enumerar expedientes.	Media	Requisito SEC-05 y ciclo TDD 1; corregido.	H-01
OBS-02	Los oráculos de TC-02/TC-10 solo buscaban la clave `nota`, no `sede` ni el estado de los datos tras la denegación.	Baja	Nuevos `assertSinDatosProtegidos` y `assertExpedientesIntactos`; corregido.	H-05
OBS-03	La caducidad de sesión era solo una bandera y la bandera `expirada` no tenía prueba propia (mutante M-07 vivo).	Alta / Baja	Ciclo TDD 2 y prueba TC-04c; corregido.	H-02, H-05
OBS-04	Los intentos sin sesión válida y las revocaciones no quedan en la bitácora.	Baja	Aceptado como riesgo residual: requiere política adicional.	H-06

Revisión de las pruebas inspeccionadas

Pregunta	TC-03	TC-12
¿Comprueba el efecto sobre los datos?	Sí: `assertExpedientesIntactos` compara los expedientes completos antes y después.	Sí: compara la respuesta completa (código y cuerpo) de IDs ajenos frente a inexistentes.
¿Es independiente?	Sí: `setUp` crea un estado nuevo y una copia profunda por prueba; no depende de otras pruebas.	Sí: mismo mecanismo; la prueba de API usa un servidor y un estado nuevos.
¿Puede fallar cuando el control falla?	Sí: la mutación M-02 (quitar la comprobación de sede) la hace fallar.	Sí: la mutación M-09 (404 para todos los roles) la hace fallar.

4.2 Usabilidad y reproducibilidad

Reproducibilidad con un compañero

Registro de la ejecución de la suite siguiendo únicamente el `README.md`. El procedimiento también se verificó en clones nuevos del repositorio (sección 3.5).

Campo	Registro
Compañero	Bernal Santiago Vargas Solís
Fecha	30/10/2026
Sistema y Python	Equipo propio del compañero; Python 3.10 o superior, como indica el README
¿Los pasos del README fueron suficientes?	Sí
Dificultades encontradas	Ninguna: siguiendo solo el README, la suite terminó con 34 pruebas en verde (OK).

Mensajes de seguridad: sesión inválida y acceso denegado

Situación	Mensaje actual	Claridad	Divulgación	Valoración y mejora
Sesión inválida (ausente, desconocida, revocada o vencida)	401 · `{"error": "No autenticado"}`	Indica que falta autenticación válida, pero no distingue si debe iniciar sesión de nuevo o corregir el token.	Ninguna: no revela si el token existió ni cuándo venció; evita sondeo de tokens.	Seguro y suficientemente claro. Mejora propuesta (H-09): enviar `WWW-Authenticate: Bearer` y aceptar el esquema sin distinguir mayúsculas.
Acceso denegado (rol, sede o propiedad)	403 · `{"error": "Operación denegada"}`	Dice que la operación no se permitió, sin explicar el motivo (rol, sede o ID).	Ninguna: sin nota, estudiante ni sede, y es idéntico para IDs ajenos e inexistentes (SEC-05).	Aceptable para datos académicos: prioriza la confidencialidad; el diagnóstico queda en la bitácora (usuario, acción, ID y resultado).

Ajustes de nombres, datos y mensajes en las pruebas

Antes	Después	Motivo
test_N01_estudiante_no_consulta_expediente_ajeno	test_TC02_estudiante_no_lee_expediente_ajeno	El nombre incluye el ID del caso; la aserción ahora indica `lectura ajena` y se agrega la comprobación de que los expedientes no cambiaron.
test_F03_expediente_inexistente_da_404_sin_datos	test_TC12_expediente_inexistente_no_permite_enumerar_ids	El nombre describe el comportamiento de seguridad (no enumerar IDs); el mensaje de fallo explica la causa: `404 vs 403 permite enumerar expedientes`.
test_N02 / test_N03 (revocada, vencida)	test_TC04a / test_TC04b / test_TC04c	Un identificador por escenario facilita el diagnóstico: la prueba que falla indica si fue sesión revocada, vencida o con bandera.
test_X01_auditoria_no_contiene_tokens	test_TC15_auditoria_registra_denegados_y_nunca_tokens	Se verifica la secuencia exacta de resultados [permitida, permitida, denegada] además de la ausencia de tokens, y el mensaje muestra el registro filtrado.

4.3 Registro de hallazgos

Plantilla A.2 completa en `hallazgos.csv` (19 campos por hallazgo). Resumen:

ID	Título	Sev.	Requisito	Casos	Estado final	Commits
H-01	Enumeración de expedientes por diferencia 404/403	Media	SEC-05	TC-12, TC-20	Corregido y verificado	a501914 (rojo), d7fe59d (verde), e29e531 (refactor)
H-02	La caducidad de la sesión dependía solo de una bandera manual	Alta	SEC-03	TC-19	Corregido y verificado	335dfc4 (rojo), 7f7fd23 (verde), a3719fd (refactor)
H-03	El servidor interpretaba el cuerpo antes de autenticar	Baja	SEC-03	TC-22	Corregido y verificado	ec13a34 (rojo), 724193d (verde), 7eff45f (refactor)
H-04	El 401 podía perderse si el cliente enviaba cuerpo	Baja	SEC-03, SEC-07	TC-23	Corregido y verificado	9f73de3 (rojo), fff5be1 (verde), dafa7ba (refactor)
H-05	Debilidades de la propia suite (fallo de la prueba, no del producto)	Baja	SEC-01, SEC-03	TC-02, TC-10, TC-04	Corregido y verificado	8ca9385, b6fc0a5
H-06	Los intentos sin sesión válida y las revocaciones no se auditan	Baja	SEC-06	TC-15	Aceptado formalmente como riesgo residual	-
H-07	Estado compartido sin cerrojo ante solicitudes concurrentes	Baja	SEC-02	-	Aceptado formalmente como riesgo residual	-
H-08	No existe un manejador general de excepciones en el servidor	Baja	SEC-07	TC-17, TC-18	Aceptado formalmente como riesgo residual	-
H-09	El 401 no envía WWW-Authenticate y el esquema Bearer distingue mayúsculas	Baja	SEC-03	TC-13	Abierto	-

H-01 — Enumeración de expedientes por diferencia 404/403

Campo	Contenido
Severidad	Media
Justificación de la severidad	Divulgación limitada (existencia de IDs), explotable por cualquier usuario autenticado y automatizable.
Activo	A-01
Requisito	SEC-05
Casos afectados	TC-12, TC-20
Amenaza	R-07
Pasos para reproducir	1) Autenticarse como Ana. 2) GET /expedientes/999 → 404. 3) GET /expedientes/202 → 403. 4) Comparar.
Resultado esperado	Misma respuesta (403) para un ID inexistente y uno ajeno.
Resultado observado	404 `No existe` frente a 403 `Operación denegada`.
Impacto	Permite descubrir qué expedientes existen.
Estado del hallazgo	Confirmado
Corrección o tratamiento	`leer_expediente` y `actualizar_nota` responden 403 por la misma función `_denegar`; solo el administrador recibe 404.
Commits	a501914 (rojo), d7fe59d (verde), e29e531 (refactor)
Evidencia	evidencias/tdd/ciclo1_*.txt; PM-07 y PM-08 en pruebas_manuales_api.md
Fecha	2026-10-30
Estado final	Corregido y verificado
Prueba de cierre	TC-12 y TC-20 en verde; mutantes M-09 y M-10 detectados.

H-02 — La caducidad de la sesión dependía solo de una bandera manual

Campo	Contenido
Severidad	Alta
Justificación de la severidad	Una sesión nunca caducaba por tiempo: un token filtrado seguía válido indefinidamente.
Activo	A-03
Requisito	SEC-03
Casos afectados	TC-19
Amenaza	R-04
Pasos para reproducir	1) Fijar `expira_en` en el pasado en una sesión sin bandera `expirada`. 2) Solicitar una lectura.
Resultado esperado	401.
Resultado observado	200 con los datos del expediente.
Impacto	Reutilización de sesiones vencidas (R-04).
Estado del hallazgo	Confirmado
Corrección o tratamiento	`expira_en` + reloj inyectable `estado["ahora"]`; `_sesion_vigente` unifica la regla.
Commits	335dfc4 (rojo), 7f7fd23 (verde), a3719fd (refactor)
Evidencia	evidencias/tdd/ciclo2_*.txt
Fecha	2026-10-30
Estado final	Corregido y verificado
Prueba de cierre	TC-19a/b/c/d en verde; mutante M-08 detectado.

H-03 — El servidor interpretaba el cuerpo antes de autenticar

Campo	Contenido
Severidad	Baja
Justificación de la severidad	Revela reglas de validación a un cliente sin sesión; sin acceso a datos.
Activo	A-06
Requisito	SEC-03
Casos afectados	TC-22
Amenaza	R-08
Pasos para reproducir	1) POST /expedientes/101/nota sin token con cuerpo `{nota:`.
Resultado esperado	401.
Resultado observado	400 `JSON inválido`.
Impacto	Divulgación de comportamiento interno a no autenticados.
Estado del hallazgo	Confirmado
Corrección o tratamiento	Se autentica en `do_POST` antes de `_leer_nota`.
Commits	ec13a34 (rojo), 724193d (verde), 7eff45f (refactor)
Evidencia	evidencias/tdd/ciclo3_*.txt
Fecha	2026-10-30
Estado final	Corregido y verificado
Prueba de cierre	TC-22 en verde; mutante M-13 detectado.

H-04 — El 401 podía perderse si el cliente enviaba cuerpo

Campo	Contenido
Severidad	Baja
Justificación de la severidad	Afecta disponibilidad/diagnóstico del control de sesiones; intermitente; sin fuga de datos.
Activo	A-06
Requisito	SEC-03, SEC-07
Casos afectados	TC-23
Amenaza	R-08
Pasos para reproducir	1) Repetir 200 veces POST sin token con ~900 bytes de cuerpo.
Resultado esperado	401 siempre.
Resultado observado	`ConnectionAbortedError` (RST) en parte de las solicitudes.
Impacto	El cliente no recibe la denegación; comportamiento no determinista.
Estado del hallazgo	Confirmado
Corrección o tratamiento	`_descartar_cuerpo` consume (sin interpretar) hasta 1024 bytes antes de responder el 401.
Commits	9f73de3 (rojo), fff5be1 (verde), dafa7ba (refactor)
Evidencia	evidencias/tdd/ciclo4_*.txt
Fecha	2026-10-30
Estado final	Corregido y verificado

Campo	Contenido
Prueba de cierre	TC-23 en verde (200 repeticiones) y 5 corridas completas sin intermitencia.

Los detalles de H-05 a H-09 están en `hallazgos.csv`.

4.4 Resultados no concluyentes y fallos de la propia prueba

ID	Situación	Clasificación	Explicación técnica
NC-01	bandit sin hallazgos	Resultado no concluyente	bandit analiza patrones inseguros genéricos; no conoce la política rol-sede, por lo que 'sin hallazgos' no demuestra que la autorización sea correcta. Se complementa con la lista de comprobación y las pruebas (evidencias/sast_bandit.txt).
NC-02	Error al grabar la primera evidencia roja (UnicodeDecodeError)	Fallo de la herramienta, no del producto	`tools/registrar_evidencia.py` leyó la salida de la suite con la codificación cp1252 de Windows. Se forzó UTF-8 en el subproceso; las pruebas no cambiaron.
NC-03	Prueba intermitente TC-22 durante el ciclo 3	Falso diagnóstico inicial resuelto	El fallo ocasional parecía un problema de la prueba; la repetición de 200 solicitudes (TC-23) demostró que era un defecto real del servidor (H-04), por lo que se corrigió el producto y no la aserción.

4.5 Conclusiones

- Los controles de autorización, sesión, validación y confidencialidad se comportan según los requisitos en los 23 casos, tanto en la lógica como a través de la API.
- Los defectos reales más valiosos aparecieron al *cuestionar* el diseño (enumeración, caducidad por reloj) y al *cuestionar las pruebas* (mutación y repetición), no al ver que todo pasaba.
- La inspección estática encontró un defecto que la suite no cubría (H-03), lo que muestra que SAST y pruebas dinámicas se complementan.
- Persisten limitaciones propias de un laboratorio (auditoría de intentos sin sesión, concurrencia, sin manejador general de excepciones).

5. Indicadores calculados

Estados separados por categoría (todos los casos planificados: 23):

Aprobado	Fallido	Bloqueado	No ejecutado	Planificados
23	0	0	0	23

Indicador	Fórmula	Cálculo	Resultado
Tasa de aprobación	aprobados / (aprobados + fallidos) × 100	23 / (23 + 0) × 100	**100.0 %**
Avance	(aprobados + fallidos) / planificados × 100	(23 + 0) / 23 × 100	**100.0 %**
Cobertura de requisitos	requisitos con al menos una prueba válida / requisitos definidos × 100	7 / 7 × 100	**100.0 %**
Tasa de aprobación (12 casos de diseño)	igual, solo TC-01 a TC-12	12 / (12 + 0) × 100	**100.0 %**

Una prueba se considera válida si está automatizada, se ejecutó y su oráculo comprueba la respuesta, la ausencia de filtración y, cuando aplica, el estado de los datos; la validez se respalda con la prueba de mutación (15/15). Las cifras salen de la ejecución real de la suite al generar este informe.

Indicadores por paso TDD

Ciclo	Paso	Commit	Pruebas	Aprobadas	Fallidas	Tasa
1	ROJO	`a501914`	27	25	2	92.6 %
1	VERDE	`d7fe59d`	27	27	0	100.0 %
1	REFACTOR	`e29e531`	27	27	0	100.0 %
2	ROJO	`335dfc4`	31	27	4	87.1 %
2	VERDE	`7f7fd23`	31	31	0	100.0 %
2	REFACTOR	`a3719fd`	31	31	0	100.0 %
3	ROJO	`ec13a34`	32	31	1	96.9 %
3	VERDE	`724193d`	32	32	0	100.0 %
3	REFACTOR	`7eff45f`	32	32	0	100.0 %
4	ROJO	`9f73de3`	34	33	1	97.1 %
4	VERDE	`fff5be1`	34	34	0	100.0 %
4	REFACTOR	`dafa7ba`	34	34	0	100.0 %

La tasa en los pasos rojos es baja a propósito: demuestra que las pruebas nuevas detectan el defecto antes de corregirlo.

6. Decisión de liberación

> **Liberar con condiciones** para el alcance del laboratorio (uso didáctico local en 127.0.0.1 con datos sintéticos). **No liberar** para cualquier uso real o publicación.

Justificación. No hay defectos críticos de autorización abiertos: los 5 hallazgos confirmados relevantes están corregidos y verificados con rojo-verde-refactor y regresión completa, y las pruebas demostraron poder fallar (mutación 15/15). Aun así, **una tasa de aprobación de 100 % no autoriza por sí sola la liberación**: la cobertura se limita a los casos diseñados.

Defectos y riesgos abiertos

ID	Hallazgo	Severidad	Tratamiento
H-06	Los intentos sin sesión válida y las revocaciones no se auditan	Baja	Aceptado formalmente como riesgo residual

ID	Hallazgo	Severidad	Tratamiento
H-07	Estado compartido sin cerrojo ante solicitudes concurrentes	Baja	Aceptado formalmente como riesgo residual
H-08	No existe un manejador general de excepciones en el servidor	Baja	Aceptado formalmente como riesgo residual
H-09	El 401 no envía WWW-Authenticate y el esquema Bearer distingue mayúsculas	Baja	Abierto

Condiciones de la decisión

- Se aceptan formalmente H-06, H-07 y H-08 como riesgo residual para el uso didáctico local.
- H-09 (cabecera `WWW-Authenticate` y esquema Bearer sin distinguir mayúsculas) se programa para la siguiente iteración.
- El servicio no se expone fuera de 127.0.0.1 ni se usa con datos reales.
- Antes de cualquier uso multiusuario: almacenamiento con control de concurrencia (H-07) y auditoría de los intentos sin sesión válida (H-06).

Riesgo residual (para cualquier uso real)

- La autenticación es sintética: tokens de texto fijo sin firma, contraseña ni rotación; la caducidad usa un reloj local y un TTL fijo.
- No hay HTTPS, límite de intentos ni protección contra fuerza bruta; los intentos fallidos no se auditan (H-06).
- El almacenamiento es memoria del proceso, sin cerrojo ante concurrencia (H-07) y sin aislamiento por sede a nivel de datos.
- La bitácora vive en memoria y no es inmutable.
- Un administrador distingue 404 de 403, por lo que puede enumerar IDs (es coherente con su rol de lectura global).

Responsable de la decisión (hipotético): Josué David Solís Gamboa (responsable de la decisión de liberación, rol hipotético)

Limitaciones del estudio

- No se conserva la versión vulnerable original del laboratorio; el rojo documentado corresponde a debilidades que seguían abiertas (sección 3.4).
- No se ejecutó un escaneo DAST automatizado (es optativo); el análisis dinámico fue manual (sección 3.6) y mediante pruebas de integración.
- No se probó concurrencia, rendimiento ni resistencia a denegación de servicio.
- La prueba de mutación usa 15 mutaciones elegidas por el autor; no prueba todas las regresiones posibles.
- El resultado de bandit es no concluyente para la lógica de negocio.

7. Contribución del equipo y trazabilidad de commits

Requisito del enunciado: al menos 2 commits significativos por integrante, en al menos 2 días distintos. Los números se calculan con `git log` y los nombres de autor de `informe/equipo.json`.

Integrante	Autor Git	Aporte	Commits	Días distintos	Estado del requisito
Josué David Solís Gamboa	Josué David Solís Gamboa	Trabajo conjunto en todas las fases (requisitos, casos, TDD, inspección, informe)	0	0	**No cumple aún** (se requieren ≥ 2 commits en ≥ 2 días distintos)
Bernal Santiago Vargas Solís	BSVS777	Trabajo conjunto en todas las fases (requisitos, casos, TDD, inspección, informe)	27	1	**No cumple aún** (se requieren ≥ 2 commits en ≥ 2 días distintos)

8. Uso de asistentes de IA

El equipo utilizó el asistente de IA **Claude Code** (Anthropic) como apoyo para proponer y redactar casos de prueba, aplicar los ciclos TDD, escribir las herramientas de evidencia y de mutación, realizar la inspección estática y generar los CSV y este informe. Todas las pruebas y comandos citados se ejecutaron en el laboratorio local y sus salidas se conservan en `evidencias/`.

9. Cumplimiento de las reglas de ejecución y seguridad

- Todas las pruebas se ejecutaron en el laboratorio local (127.0.0.1) y no se evaluó ningún sistema real.
- Solo se usaron cuentas, tokens y datos ficticios; el repositorio no contiene credenciales ni información personal reales.
- No se alteró ninguna aserción para ocultar un fallo confirmado. El único cambio de expectativa (TC-12, de 404 a 403 para no administradores) responde a un nuevo requisito (SEC-05) y se documentó en el commit rojo del ciclo 1.
- El proyecto usa solo Python y su biblioteca estándar; bandit se usó únicamente como herramienta SAST opcional.

Anexo: archivos entregados

Archivo	Contenido
informe_seguridad.pdf	Este informe.
README.md	Entorno, instalación, comandos exactos y restablecimiento de datos.
src/, servidor.py, tests/	Código fuente y pruebas (unidad e integración).
matriz_trazabilidad.csv, casos_prueba.csv, hallazgos.csv	Matriz requisito-riesgo-caso, registro de casos (A.1) y bitácora de hallazgos (A.2).
evidencias/	TDD (rojo-verde-refactor con hashes), ejecuciones limpias, pruebas manuales, inspección estática, bandit y mutación.
tools/, informe/	Herramientas reproducibles: registrar evidencia, ejecución limpia, mutación y generador de este informe.